

Rapport d'incident de sécurité

Investigation automatisée des journaux Windows

Période analysée : du 12/03/2026 08:00 au 12/03/2026 08:40 UTC
Source : logs_test.json (73 événements) · heures en UTC

GRAVITÉ : CRITIQUE

En bref

L'analyse de 73 événements a mis en évidence 1 source qui a tenté de deviner des mots de passe : 203.0.113.47 (password spraying, c'est-à-dire un même mot de passe essayé sur de nombreux comptes ; 14 comptes visés).

L'attaquant a réussi à entrer : il s'est connecté sur WKS-014 avec le compte j.martin à 08:21 (depuis 203.0.113.47).

Une fois entré, l'attaquant a exécuté une commande suspecte sur WKS-014, programmé la tâche \MicrosoftUpdateSync pour revenir plus tard, créé le compte svc_backup, donné à svc_backup les droits d'administration (Administrateurs) et effacé le journal de sécurité de WKS-014 ; la gravité est jugée critique.

Actions à lancer immédiatement

1. Bloquer l'IP 203.0.113.47 au pare-feu et au proxy
2. Isoler WKS-014 du réseau
3. Réinitialiser le mot de passe de j.martin et révoquer ses sessions (le déconnecter partout)
4. Désactiver le compte svc_backup
5. Retirer svc_backup du groupe Administrateurs

Les pages suivantes détaillent le raisonnement suivi, étape par étape, la chronologie de l'attaque, le plan d'action complet et, en annexe, les indicateurs techniques à transmettre à l'équipe sécurité.

Étape 1 · DÉTECTION DES ATTAQUES PAR MOTS DE PASSE

Ce que l'on cherche : les échecs de connexion (événement 4625), regroupés par adresse IP source. Une IP est signalée à partir de 10 échecs ; au moins 5 comptes visés indiquent un password spraying (un mot de passe courant testé sur beaucoup de comptes), moins indiquent une force brute.

Ce que l'on trouve : 61 échecs de connexion analysés, venant de 3 adresses IP ; 1 suspecte.

- 203.0.113.47 : 37 échecs, 14 comptes, machines visées : SRV-DC01, WKS-003, WKS-007, WKS-011, WKS-014, WKS-022, de 08:02 à 08:18 -> profil password spraying.
- Écartée : 10.2.5.9 (23 échecs, compte : svc_sql) -> 23 échecs sur un seul compte depuis le réseau interne : probablement un compte de service dont le mot de passe a expiré.

Note : 61 de ces échecs portent pourtant result = "success" dans le journal ; cette incohérence est ignorée, l'identifiant d'événement 4625 fait foi.

Conclusion : 1 IP suspecte à examiner : l'étape 2 cherche si l'une d'elles a fini par se connecter avec succès.

Étape 2 · L'ATTAQUE A-T-ELLE ABOUTI ?

Ce que l'on cherche : pour chaque IP suspecte, les connexions réussies (événement 4624) survenues après son premier échec : l'attaquant dispose alors d'un mot de passe valide.

Ce que l'on trouve : 1 compromission ; 0 IP suspecte sans connexion réussie.

- L'attaque depuis 203.0.113.47 a abouti : le compte j.martin s'est connecté à WKS-014 à 08:21, par accès réseau ; mot de passe probablement deviné par l'attaquant.

Conclusion : L'étape 3 reconstitue l'activité sur la machine touchée : WKS-014 après 08:21.

Étape 3 · QUE FAIT L'ATTAQUANT APRÈS L'INTRUSION ?

Ce que l'on cherche : sur WKS-014, tout ce qui s'est passé à partir de 08:21 (connexion de j.martin), 2 comptes suivis : j.martin, svc_backup.

Le périmètre a été étendu au compte créé par l'attaquant : svc_backup (ses actions sur d'autres machines sont aussi suivies).

Ce que l'on trouve : 6 événements dont 6 suspects (marqués [!]).

- [!] 08:21 WKS-014 connexion de j.martin depuis 203.0.113.47 (début de la compromission)
- [!] 08:23 WKS-014 powershell.exe lancé par winword.exe (exécution suspecte) : powershell.exe -nop -w hidden -enc JABjAD0A ; commande décodée : \$c= (commande encodée, contenu masqué)
- [!] 08:25 WKS-014 tâche planifiée créée : \MicrosoftUpdateSync
- [!] 08:27 WKS-014 compte local créé : svc_backup
- [!] 08:28 WKS-014 svc_backup ajouté au groupe Administrateurs (groupe à privilèges)
- [!] 08:31 WKS-014 journal de sécurité effacé

Conclusion : L'étape 4 transforme ces constats en plan d'action : isoler les machines, désactiver les comptes, supprimer les tâches et retirer les droits obtenus.

Chronologie de l'attaque

Heure	Machine	Compte	Ce qui s'est passé
08:21	WKS-014	j.martin	connexion de j.martin depuis 203.0.113.47 (début de la compromission)
08:23	WKS-014	j.martin	powershell.exe lancé par winword.exe (exécution suspecte) : powershell.exe -nop -w hidden -enc JABjAD0A ; commande décodée : \$c= (commande encodée, contenu masqué)
08:25	WKS-014	j.martin	tâche planifiée créée : \MicrosoftUpdateSync
08:27	WKS-014	j.martin	compte local créé : svc_backup
08:28	WKS-014	j.martin	svc_backup ajouté au groupe Administrateurs (groupe à privilèges)
08:31	WKS-014	j.martin	journal de sécurité effacé

Les actions suspectes sont surlignées en rouge.

Étape 4 · PLAN D'ACTION ET GRAVITÉ

Ce que l'on cherche : à partir de 1 IP suspecte, 1 compromission et 6 événements post-intrusion, les mesures à prendre ; chaque action est rattachée au fait observé qui la justifie.

Ce que l'on trouve : gravité CRITIQUE : l'attaquant a étendu son emprise (ajout de svc_backup au groupe Administrateurs, effacement du journal de sécurité de WKS-014) ; 10 actions proposées.

Conclusion : L'étape 5 extrait les indicateurs de compromission (IP, comptes, tâches, commandes, empreintes) pour les partager et les enrichir.

Le détail des actions figure dans le tableau ci-dessous.

Plan d'action

Fait observé	Action à mener	Priorité
203.0.113.47 a échoué 37 fois à se connecter entre 08:02 et 08:18	Bloquer l'IP 203.0.113.47 au pare-feu et au proxy	IMMÉDIAT
Connexion de l'attaquant confirmée sur WKS-014 à 08:21 avec j.martin	Isoler WKS-014 du réseau	IMMÉDIAT
Connexion de l'attaquant confirmée sur WKS-014 à 08:21 avec j.martin	Réinitialiser le mot de passe de j.martin et révoquer ses sessions (le déconnecter partout)	IMMÉDIAT
Compte svc_backup créé sur WKS-014 à 08:27 par j.martin	Désactiver le compte svc_backup	IMMÉDIAT
svc_backup ajouté au groupe à privilèges Administrateurs sur WKS-014 à 08:28	Retirer svc_backup du groupe Administrateurs	IMMÉDIAT
Commande suspecte exécutée sur WKS-014 à 08:23 par j.martin	Collecter les preuves sur WKS-014 (mémoire, disque) et analyser la commande : \$c=	COURT TERME
Tâche planifiée \MicrosoftUpdateSync créée sur WKS-014 à 08:25	Supprimer la tâche planifiée \MicrosoftUpdateSync sur WKS-014	COURT TERME
Journal de sécurité effacé sur WKS-014 à 08:31 par j.martin	Traçabilité locale perdue sur WKS-014 : s'appuyer sur le SIEM (outil central de collecte des journaux) et les sauvegardes	COURT TERME
23 échecs de svc_sql depuis 10.2.5.9 (réseau interne) sur SRV-SQL01	Vérifier le mot de passe du compte de service svc_sql sur SRV-SQL01	SUIVI
203.0.113.47 a testé 14 comptes (password spraying)	Revoir la robustesse des mots de passe des 14 comptes visés par 203.0.113.47	SUIVI

Étape 5 · IOC ET ENRICHISSEMENT

Ce que l'on cherche : les indicateurs de compromission (IOC), c'est-à-dire les traces réutilisables pour détecter l'attaquant ailleurs, tirés des étapes précédentes : IP d'attaque (étape 1), comptes et machines compromis (étape 2), comptes créés, tâches planifiées, commandes suspectes et les empreintes, adresses web, domaines et IP qu'elles contiennent (étape 3).

Ce que l'on trouve : 6 IOC.

Vérification VirusTotal : enrichissement non demandé (option --enrichir).

Conclusion : IOC exportés dans iocs_misp.csv (import MISP) et iocs_stix.json (STIX 2.1, pour une plateforme de renseignement sur la menace).

La liste des indicateurs figure dans l'annexe ci-dessous.

Annexe · Indicateurs de compromission (IOC)

Indicateur	Type	Vérification VirusTotal
203.0.113.47	IP d'attaque	non vérifié
j.martin	compte compromis	non vérifié
WKS-014	machine touchée	non vérifié
powershell.exe -nop -w hidden -enc JABjAD0A	commande suspecte	non vérifié
\MicrosoftUpdateSync	tâche planifiée	non vérifié
svc_backup	compte créé	non vérifié

Rappel de prudence : ces indicateurs proviennent d'une analyse automatisée. Faites-les valider par l'équipe sécurité avant de les bloquer ou de les partager, et ne soumettez jamais de fichier interne à un service en ligne.